REPORT W12D4

Report di Vulnerability assessment e Remediation

1. Introduzione

L'obiettivo di questo laboratorio è stato effettuare una scansione delle vulnerabilità Su un sistema volutamente vulnerabile, Metasploitable 2, utilizzando lo scanner di sicurezza nessus.

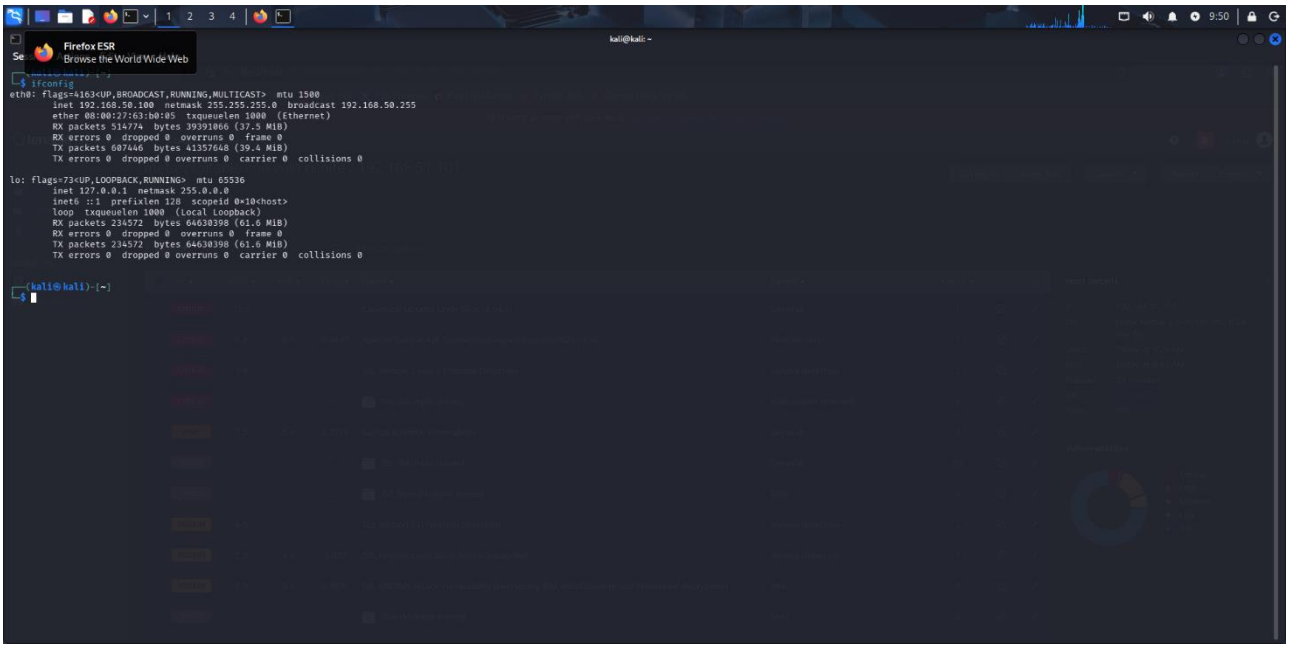
L'analisi è stata eseguita d auna macchina attaccante basata su **Kali Linux.**

Lo scopo dell'attività è stato:

- Individuare vulnerabilità e servizi esposti
- Applicare azioni di remediation
- Verificare l'efficacia delle modifiche attraverso una seconda scansione.

2. Configurazione della rete

L'ambiente di laboratorio è stato configurato utilizzando pfSense come firewall e gateway di rete.
Di seguito la configurazione:



Configurazione Kali: Ip 192.168.50.100 Gateway 192.168.50.1

```
                -n: not really
                -f: force
root@metasploitable:/home/msfadmin# netstat -tulpn | grep 2049
root@metasploitable:/home/msfadmin#
root@metasploitable:/home/msfadmin# ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:4a:12:94
          inet addr:192.168.51.101  Bcast:192.168.51.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe4a:1294/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:322395 errors:0 dropped:0 overruns:0 frame:0
          TX packets:306557 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:24261464 (23.1 MB)  TX bytes:23208725 (22.1 MB)
          Base address:0xd240 Memory:f0820000-f0840000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:4116 errors:0 dropped:0 overruns:0 frame:0
          TX packets:4116 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:1947073 (1.8 MB)  TX bytes:1947073 (1.8 MB)

root@metasploitable:/home/msfadmin#
```

Config Metasploitable: Ip 192.168.51.101 Gateway 192.168.51.1 (Su rete diversa rispetto alla kali)

```
VirtualBox Virtual Machine - Netgate Device ID: ae83404f4f0e4499eac9

*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***

 WAN (wan)       -> em0        -> v4/DHCP4: 10.0.2.15/24
 LAN (lan)       -> em1        -> v4: 192.168.50.1/24
 OPT1 (opt1)     -> em2        -> v4: 192.168.51.1/24

 0) Logout (SSH only)                  9) pfTop
 1) Assign Interfaces                 10) Filter Logs
 2) Set interface(s) IP address       11) Restart webConfigurator
 3) Reset webConfigurator password    12) PHP shell + pfSense tools
 4) Reset to factory defaults         13) Update from console
 5) Reboot system                     14) Enable Secure Shell (sshd)
 6) Halt system                       15) Restore recent configuration
 7) Ping host                         16) Restart PHP-FPM
 8) Shell

Enter an option:
Message from syslogd@pfSense at Mar 12 20:52:25 ...
php-fpm[398]: /index.php: Successful login for user 'admin' from: 192.168.50.100
 (Local Database)
[zone: pf states] PF states limit reached
[zone: pf states] PF states limit reached
```

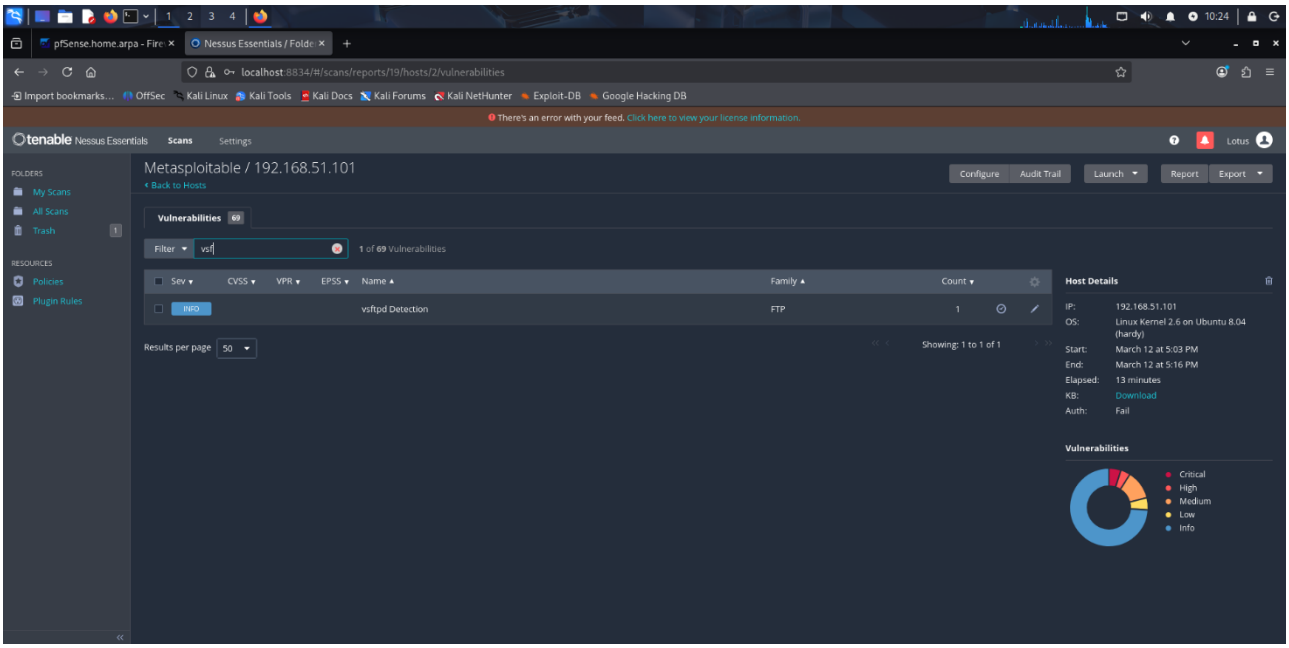
Configurazione pfSense: Rete 1 wan: 10.0.2.15 Rete 2 Lan: 192.168.50.1 Rete 3 Lan: 192.168.51.1

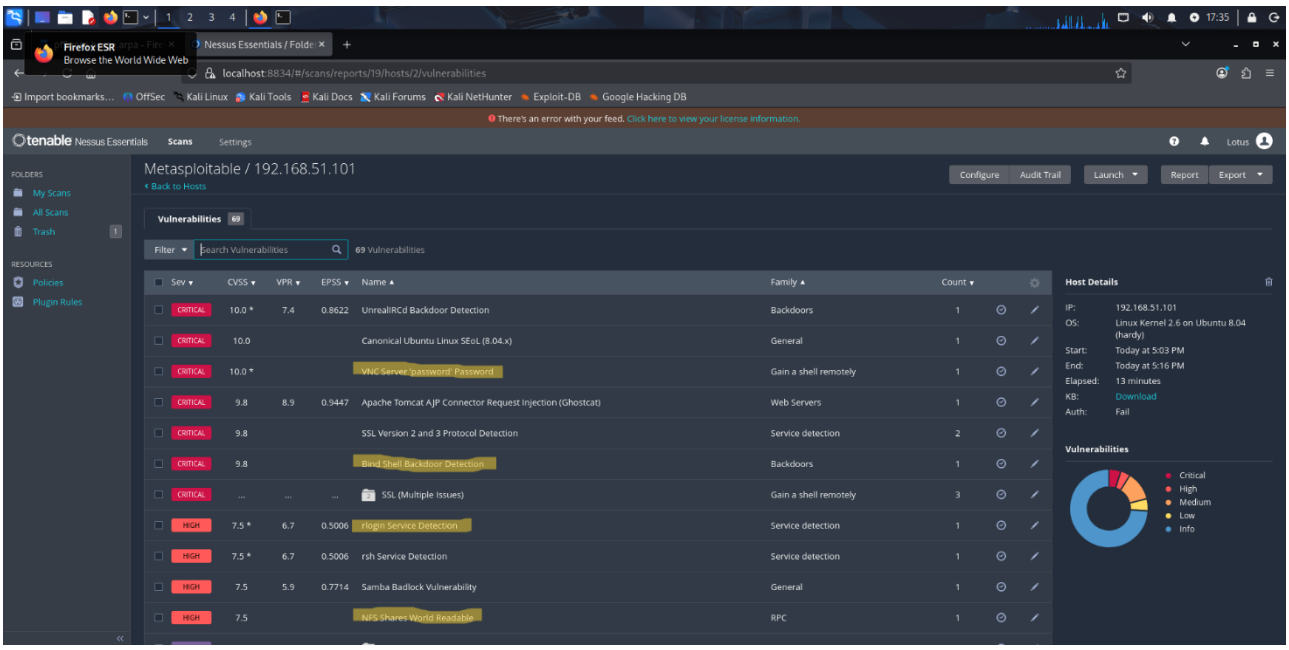
La scansione delle vulnerabilità è stata fatta dalla macchina Kali Linux verso la macchina Metasploitable(Attraverso nessus).

3. Scansione iniziale delle vulnerabilità

E' stata eseguita una prima scansione tramite Nessus per identificare i servizi vulnerabili presenti sul sistema target.

La scansione ha evidenziato diverse vulnerabilità legate a servizi insicuri e configurazioni non sicure.
Di seguito riporto le vulnerabilità selezionate evidenziate in giallo, piu' quella facoltativa che ho scelto dopo aver risolto le prime 4:

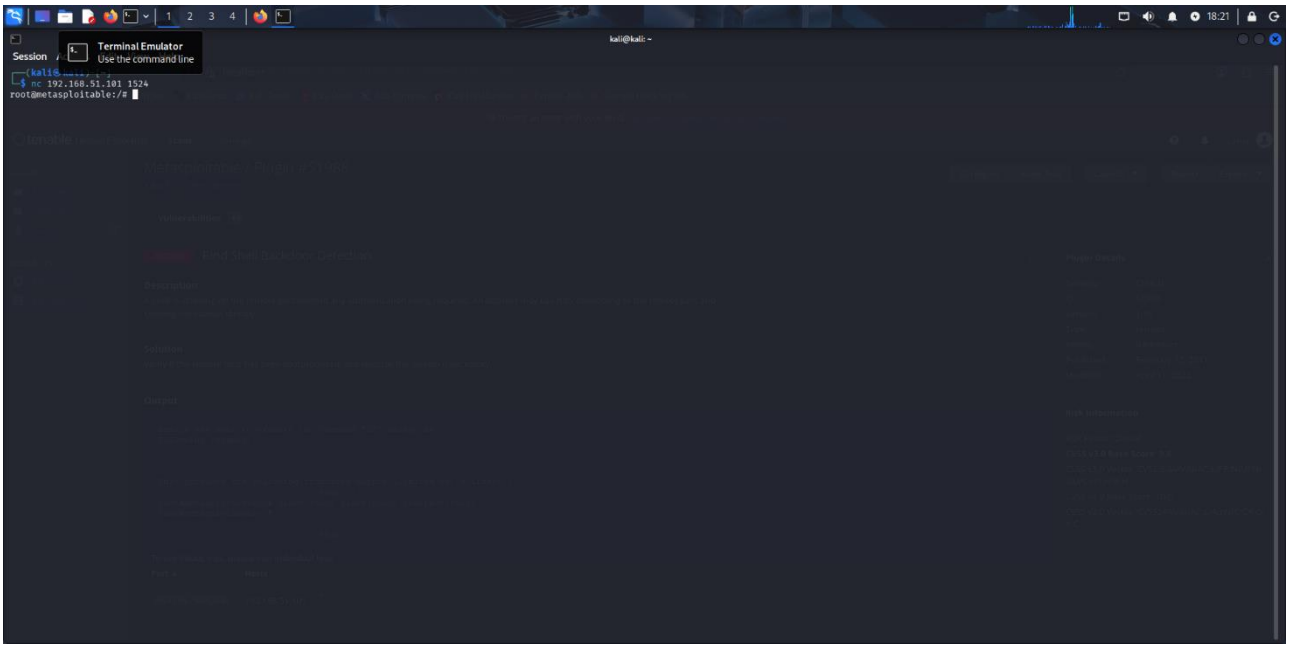




Vulnerabilità selezionate

Per il processo sono state scelte le seguenti vulnerabilità:
Rlogin Service detection: Vulnerabilità abbastanza importante, facendo una ricerca ho ottenuto queste informazioni:
rlogin è considerato un problema di sicurezza
perché è un vecchio protocollo di accesso remoto
che trasmette dati e credenziali in chiaro sulla rete.
Questo significa che un attaccante che intercetta il traffico
può facilmente ottenere username e password tramite tecniche di sniffing.

Inoltre, rlogin utilizza un meccanismo di autenticazione basato sulla fiducia tra host (file .rhosts),
che può permettere accessi non autorizzati se configurato in modo errato. Per questi motivi
il servizio è oggi considerato insicuro e obsoleto ed è stato sostituito da protocolli più sicuri come OpenSSH,
che utilizzano cifratura per proteggere le comunicazioni.
Il servizio è attivo sulla porta 513.
NFS shared world readable: Dopo una breve ricerca ecco le informazioni ottenute:
Il servizio Network File System (NFS) permette la condivisione di directory tra sistemi sulla rete.
La vulnerabilità NFS Shared World Readable indica che alcune directory esportate dal server sono accessibili
in lettura da qualsiasi host, senza adeguate restrizioni.
Questa configurazione può permettere a un attaccante di montare la share NFS e accedere a file sensibili,
come configurazioni o dati degli utenti. L'esposizione di queste informazioni può facilitare ulteriori attacchi
o la compromissione del sistema.
Nel nostro caso la vulnerabilità si trova sulla porta 2049.
VNC Server "password" password: Il servizio VNC permette l'accesso remoto all'interfaccia grafica del sistema.
La vulnerabilità rilevata da Nessus indica che il server utilizza una password debole o
di default ("password"), facilmente individuabile tramite attacchi di brute force o dizionario.
Un attaccante potrebbe quindi ottenere accesso remoto al sistema e controllarlo completamente.
Per questo motivo l'utilizzo di credenziali deboli rappresenta un serio rischio per la sicurezza.
Bind shell backdoor: la 4 vulnerabilità riguarda la porta 1524 dove troviamo disponivile una backdoor che apre una shell remota.
Una bind shell permette a un attaccante di connettersi direttamente alla macchina e ottenere una shell con
privilegi elevati, spesso senza autenticazione.
Questo rappresenta un rischio critico perché consente il controllo completo del sistema compromesso.
Come abbiamo visto anche oggi con il professore Paolo grazie a netcat da kali se è presente una shell quando andremo ad eseguire
il comando nc 192.168.51.101(ip della metasploitable) 1524(porta con la shell) dovrebbe direttamente darmi i comandi della shell. Eccone la conferma:



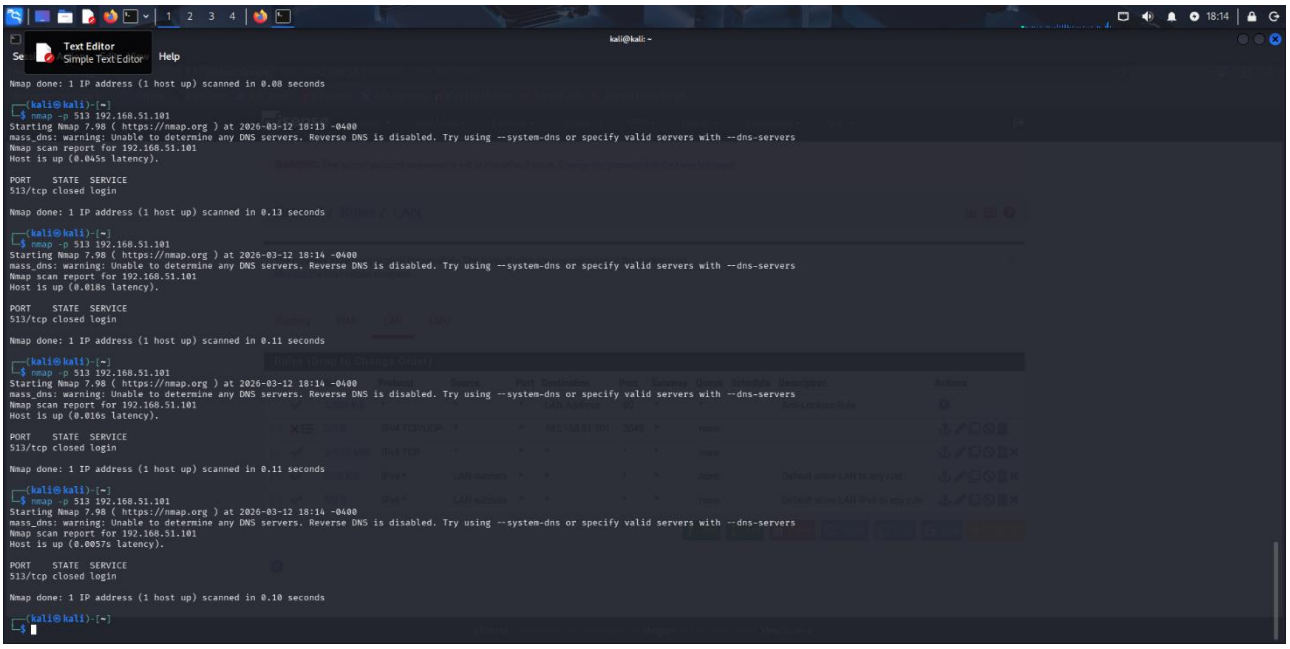
FTP service exposure: Vulnerabilità facoltativa. Ho scelto vsftpd sulla porta 21 poichè è un servizio che ho analizzato
la prima volta su nessus e ho scoperto che il servizio non crittografa i dati. quindi tutto viene trasmesso in chiaro.
ovviamente è una vulnerabilità importante.

4. Azioni di remediation

Sono state applicate diverse azioni per mitigare le vulnerabilità individuate.

rlogin Service Detecion

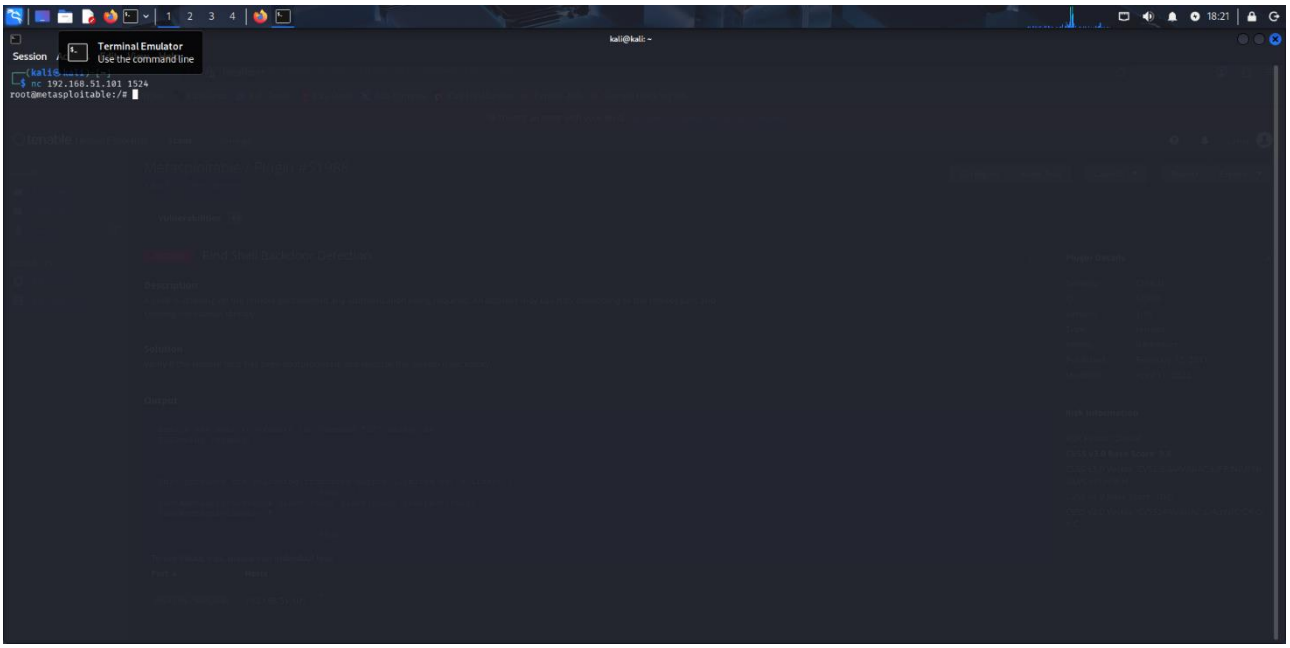
Il servizio è stato disabilitato modificando il file di configurazione /etc/inetd.conf. La riga relativa al servizio rlogin è stata commentata e il servizio è stato riavviato. Dopo la modifica la porta 513 non risultava piu' accessibile. Prima di fare la scansione completa con nessus ho voluto verificare con nmap tramite kali.



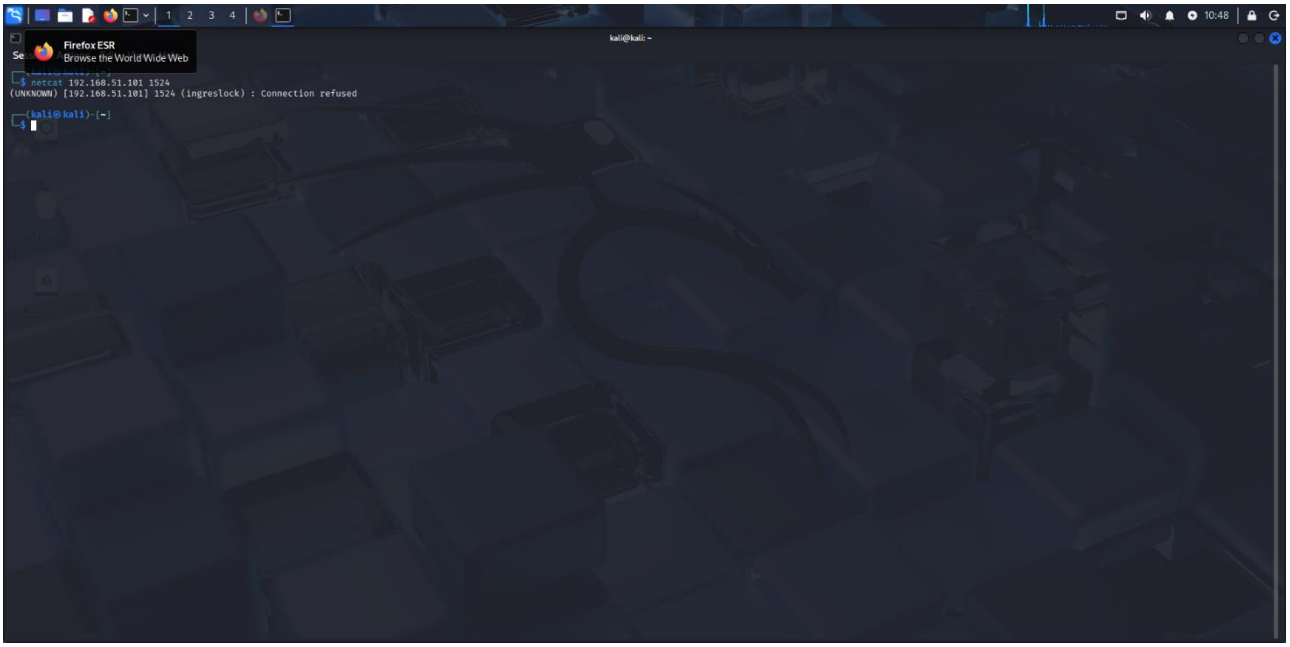
Bind Shell Backdoor

Durante la scansione è stata rilevata una bind shell in ascolto sulla porta 1524, che permetteva l'esecuzione di comandi remoti senza autorizzazione.

Per provare che la porta dia effettivamente accesso alla bind shell ho usato il comando netcat da kali sulla porta 1524 ed effettivamente mi ha restituito una shell con permessi di root senza il bisogno di inserire le credenziali:



Il processo responsabile è stato individuato utilizzando netstat -tulpn | grep 1524
Successivamente terminato tramite kill -9 4551 che era il PID del servizio attivo sulla porta.
Ho riprovato il comando netcat prima di fare la scansione completa su nessus e la porta era effettivamente non accessibile:



Password debole del server VNC

Il server VNC utilizzava una password molto debole (“password”), permettendo potenzialmente l’accesso non autorizzato.
La password è stata modificata utilizzando il comando:
vncpasswd e successivamente il servizio è stato riavviato.

```
Save modified buffer (ANSWERING "No" WILL DESTROY CHANGES) ?

root@metasploitable:/home/msfadmin#
root@metasploitable:/home/msfadmin# vncpasswd
Using password file /root/.vnc/passwd
Password:
Verify:
Passwords do not match. Please try again.

Password:
Warning: password truncated to the length of 8.
Verify:
Passwords do not match. Please try again.

Password:
Verify:
Would you like to enter a view-only password (y/n)? n
root@metasploitable:/home/msfadmin# _
```

NFS shared world readable

Il servizio Networl file system permetteva l'accesso pubblico alle directory condivise, esponendo file potenzialmente sensibili.

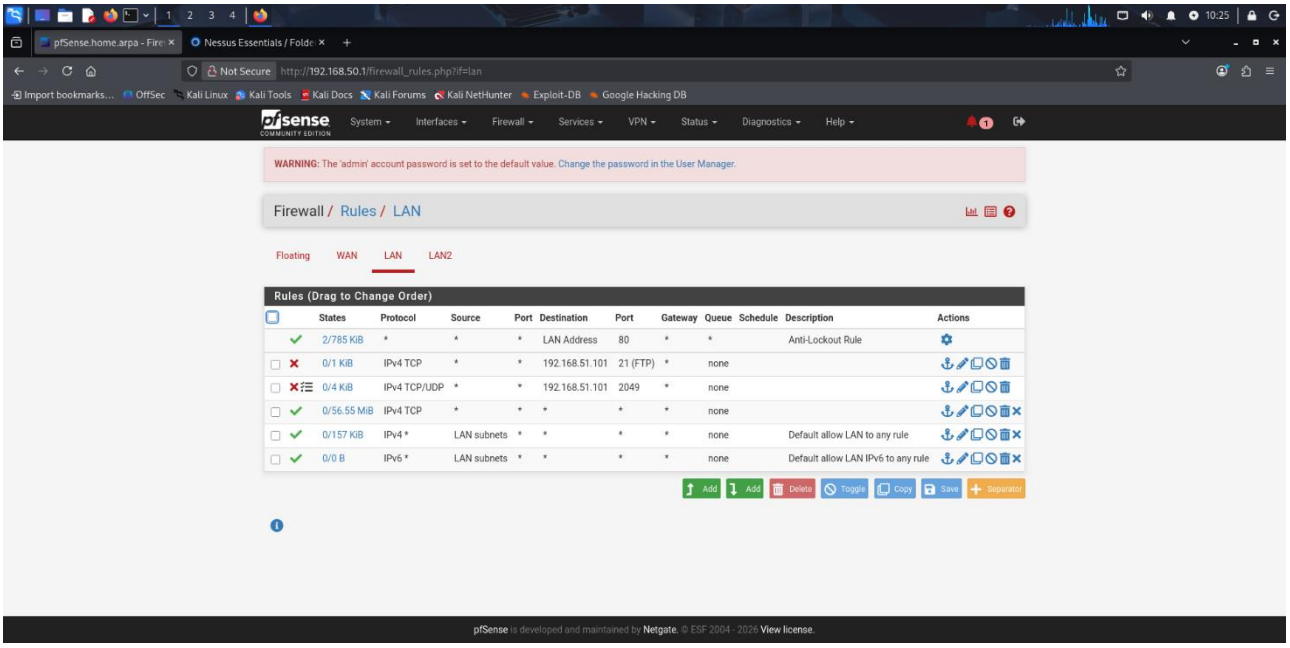
Per mitigare la vulnerabilità potremmo disabilitare il servizio NFS tramite il comando:

/etc/init.d/nfs-kernel-server stop

In questo modo la condivisione dei file non è piu' accessibile dalla rete.

Ma approfittando del fatto che stiamo facendo esercitazione sulle policy del firewall ho deciso di bloccare l'accesso alla porta 2049 (Quella dove si trova il servizio nfs attivo)

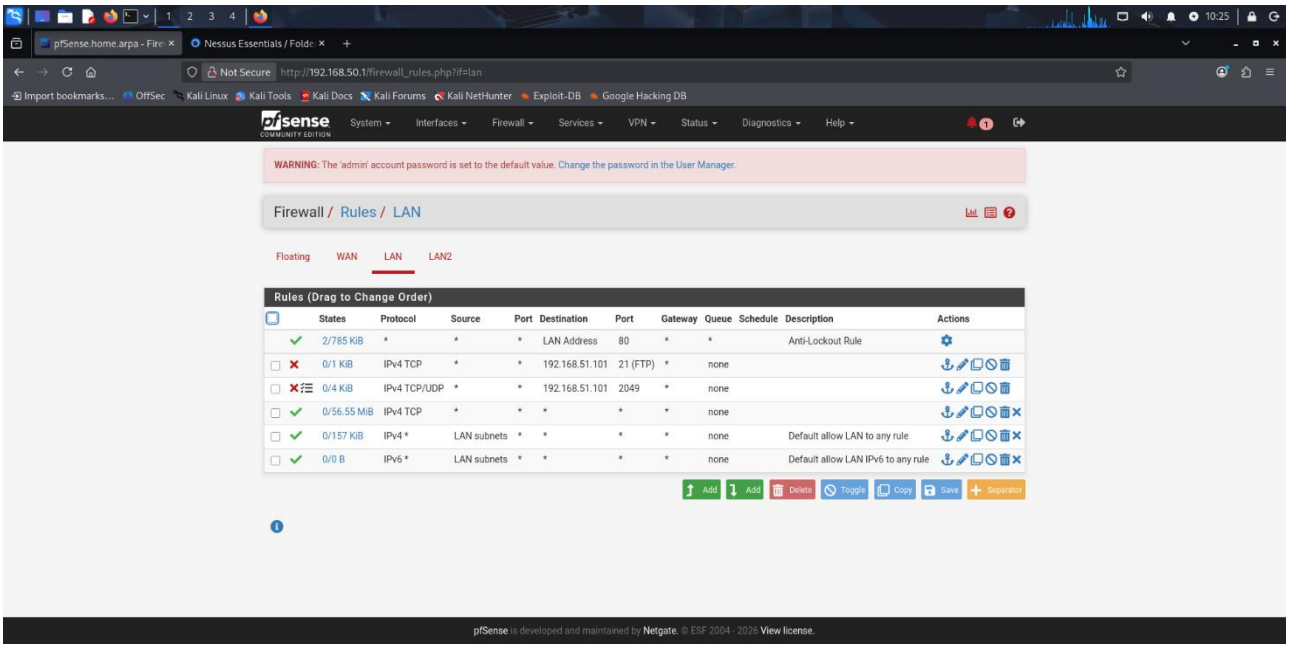
Dal firewall pfsense:



Con questa regola solo gli admin possono accedere al servizio.

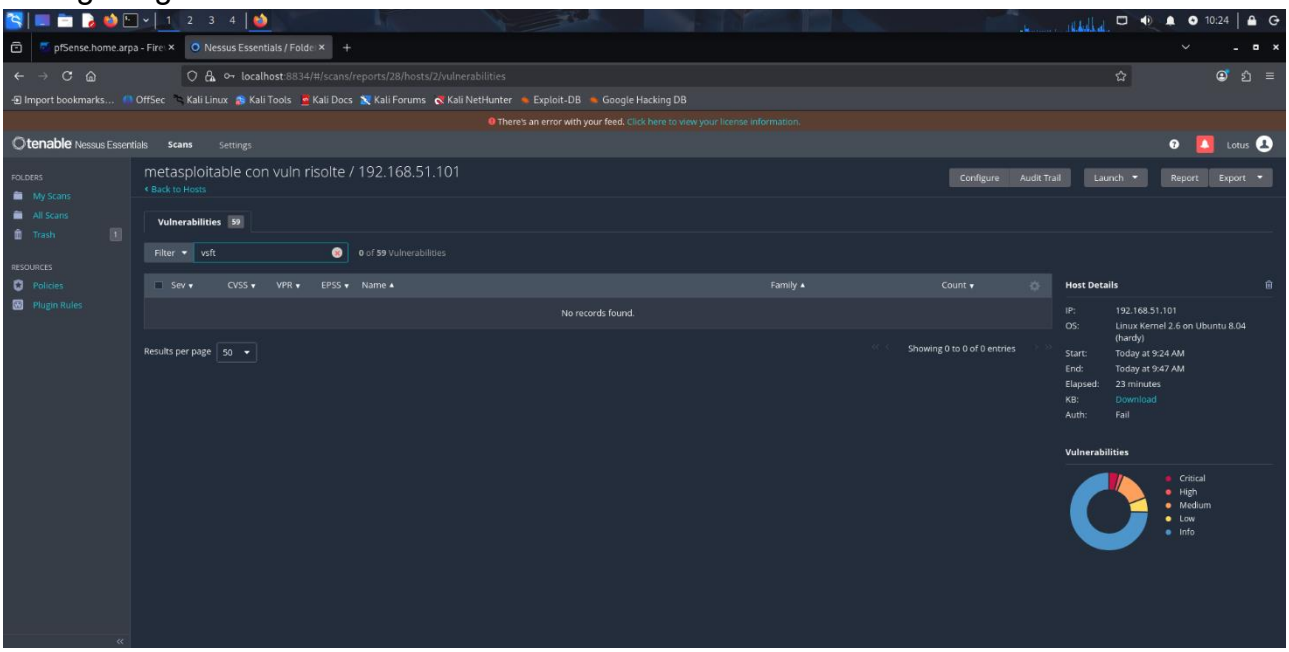
Esposizione del servizio FTP(facoltativa)

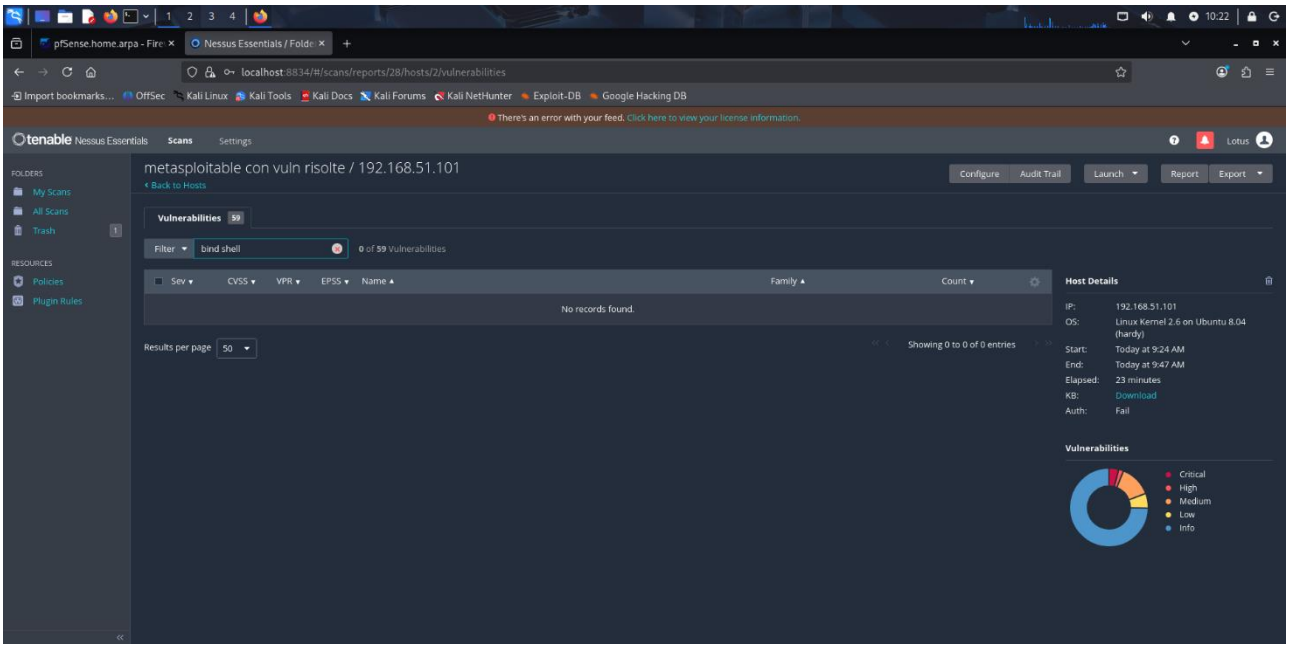
Il server FTP vsftpd risultava accessibile sulla porta 21.
Il protocollo FTP trasmette dati e credenziali senza cifratura.
L'accesso al servizio FTP è stato limitato tramite una regola firewall configurata su pfSense che blocca il traffico verso la porta 21.

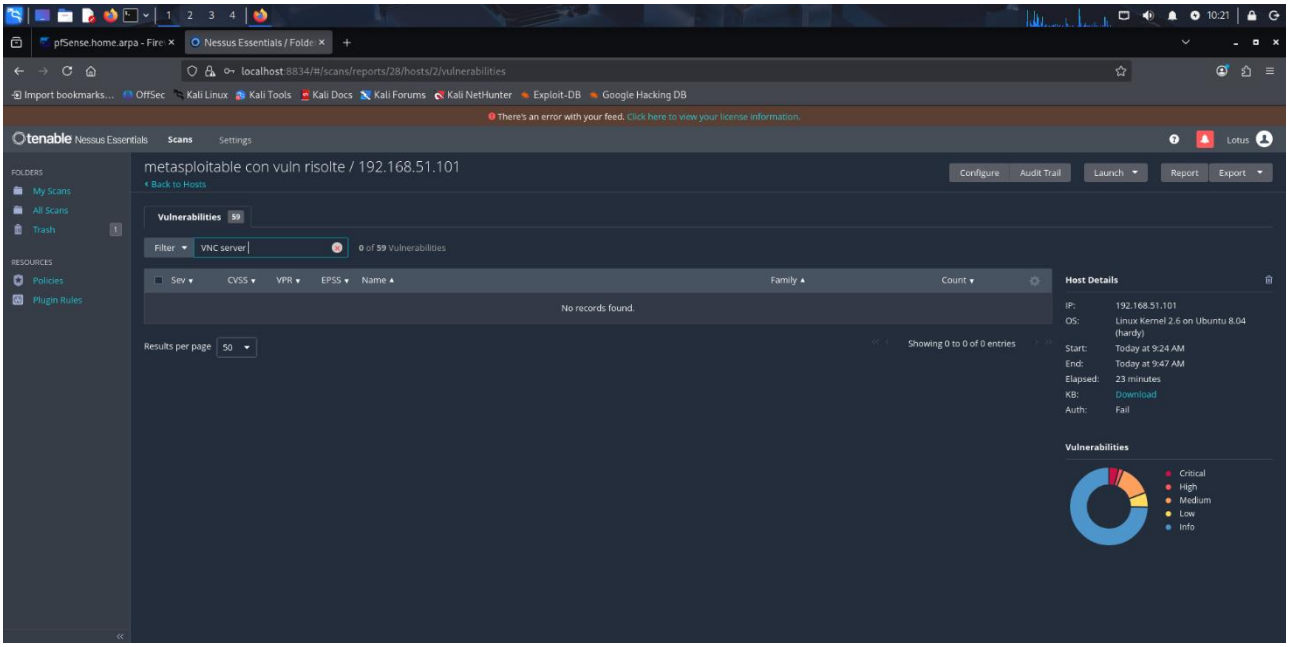


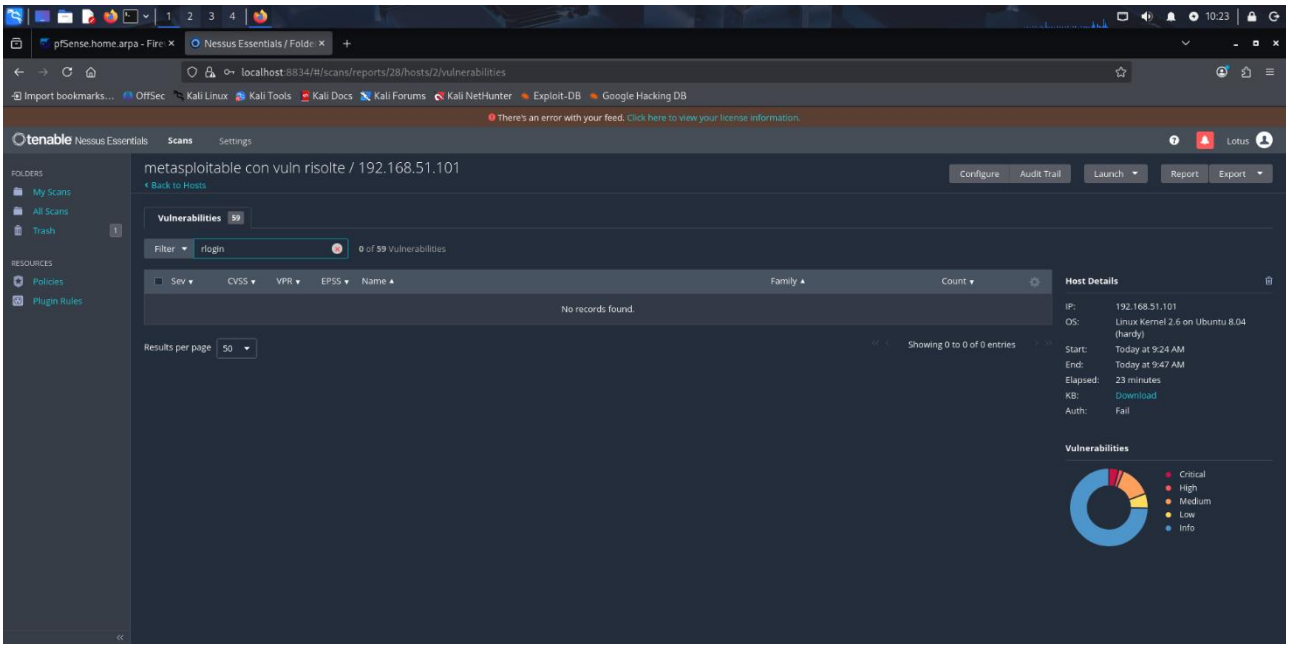
5. Scansione finale

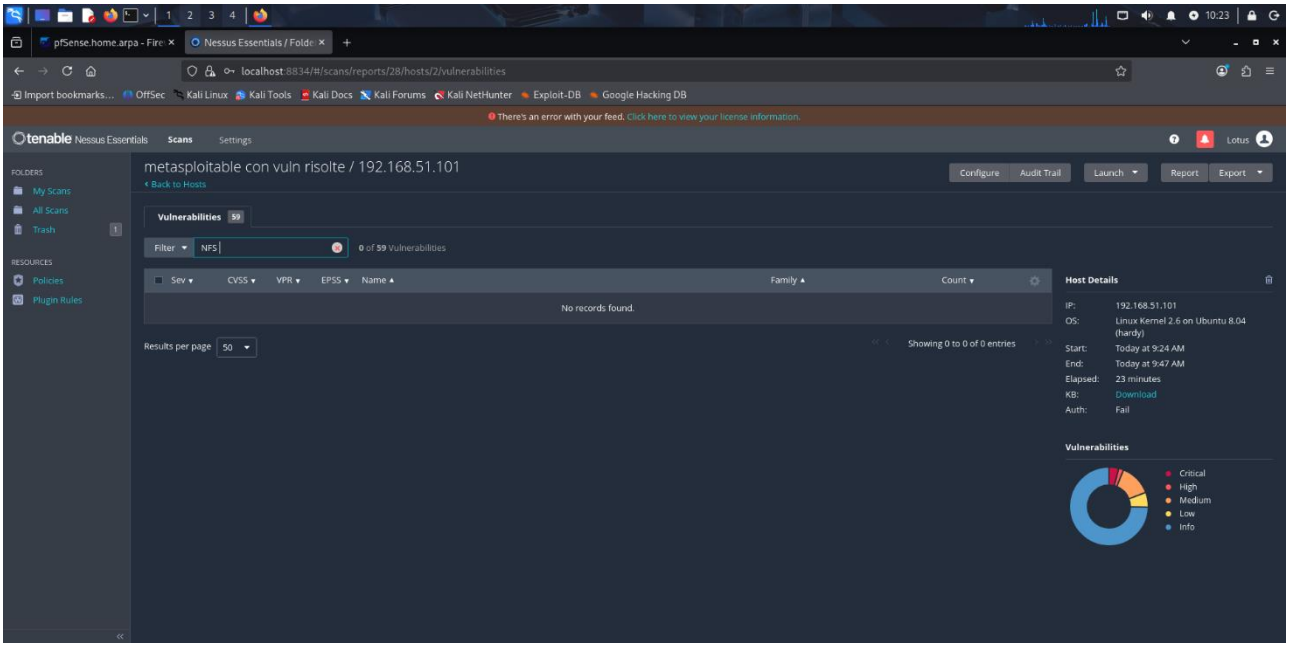
Dopo aver applicato le azioni di remediation è stata eseguita una seconda scansione utilizzando nuovamente nessus.
I risultati hanno mostrato che le vulnerabilità precedentemente identificate sono state mitigate o non risultano piu' accessibili:
Di seguito gli screen delle vulnerabilità che non risultano sulla scansione finale




pfSense.home.arpa - Fire
Nessus Essentials / Folde
localhost:8834/#/scans/reports/28/hosts/2/vulnerabilities
Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
There's an error with your feed. Click here to view your license information.
tenable Nessus Essentials
Scans
Settings
Lotus
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
metasploitable con vuln risolte / 192.168.51.101
Back to Hosts
Configure
Audit Trail
Launch
Report
Export
Vulnerabilities 59
Filter
bind shell
0 of 59 Vulnerabilities
Sev
CVSS
VPR
EPSS
Name
Family
Count
No records found.
Results per page 50
Showing 0 to 0 of 0 entries
Host Details
IP: 192.168.51.101
OS: Linux Kernel 2.6 on Ubuntu 8.04 (hardy)
Start: Today at 9:24 AM
End: Today at 9:47 AM
Elapsed: 23 minutes
KB: Download
Auth: Fail
Vulnerabilities
Critical
High
Medium
Low
Info


pfSense.home.arpa - Fire
Nessus Essentials / Folde
localhost:8834/#/scans/reports/28/hosts/2/vulnerabilities
Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
There's an error with your feed. Click here to view your license information.
tenable Nessus Essentials
Scans
Settings
Lotus
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
metasploitable con vuln risolte / 192.168.51.101
Back to Hosts
Configure
Audit Trail
Launch
Report
Export
Vulnerabilities 59
Filter
VNC server
0 of 59 Vulnerabilities
Sev
CVSS
VPR
EPSS
Name
Family
Count
No records found.
Results per page 50
Showing 0 to 0 of 0 entries
Host Details
IP: 192.168.51.101
OS: Linux Kernel 2.6 on Ubuntu 8.04 (hardy)
Start: Today at 9:24 AM
End: Today at 9:47 AM
Elapsed: 23 minutes
KB: Download
Auth: Fail
Vulnerabilities
Critical
High
Medium
Low
Info





Come si puo notare dagli screen ho eseguito la medesima scansione precedente sulla stessa macchina. Ho cercato tramite la funzione “Cerca vulnerabilità” i nomi delle vulnerabuilità che abbiamo risolto ed effettivamente non risultano. Quindi abbiamo la prova che sono state risolte.

6. Conclusioni

Il laboratorio ha dimostrato come servizi non sicuri e configurazioni errate possano esporre un sistema a potenziali attacchi.
Attraverso la disabilitazione dei servizi vulnerabili, la modifica delle credenziali e l’implementazione di regole firewall tramite pfSense, è stato possibile ridurre significativamente la superficie di attacco del sistema(Non nel caso di metasploitable poiché ne rimangono altre 100 e oltre, ma è una macchina creata proprio per questo. Su una macchina reale varrebbe il “significativamente”),
La scansione finale ha confermato l’efficacia delle zioni di remediation applicate.